

منصة شاهين الرقمية
سياسة إدارة الوصول وحماية المستخدمين
نوفمبر 2025



Internal

DO NOT COPY

الاسم المسجل : شركة الوثيقة الماسية لوساطة التأمين
المركز الرئيسي : طريق الشمامة , الربيع , الرياض
مسؤول المستند : مدير إدارة الجودة والتطوير

المحتويات	
1	المقدمة
2	الهدف من السياسة
3	تعريف
4	نطاق تطبيق السياسة
5	القطاعات والإدارات ذات العلاقة
6	الكيانات ذات العلاقة
7	قواعد عامة
8	مسؤولية السياسة
9	التعاميم والتعليمات ذات العلاقة
10	حفظ السياسة
11	مخالفة السياسة



إدارة الجودة والتطوير Quality & Development Management

المادة (1): يحتوي هذا المستند على المعلومات المتعلقة بمنصة شاهين الرقمية ولا يجوز استخدام أو نسخ هذا المستند أو المعلومات التي يحتوي عليها كاملة أو جزءاً منها أو كشفه إلى الغير ما لم تقدم شركة الوثيقة الماسية (دايموند) موافقتها الكتابية على ذلك. لا يجوز تعديل أو حذف هذا التصريح المقيد في أي حالة من هذا المستند.

المادة (2): في حال وجود اختلاف بين النص العربي والإنجليزي فإن السيادة تكون للنص العربي.



معلومات السياسة				
سياسة إدارة الوصول وحماية المستخدمين			عنوان السياسة	
مُستحدثة			حالة السياسة	
لا يوجد			عنوان السياسة السابقة	
لا يوجد			تاريخ السياسة السابقة	
بعد مُرور سنتين من تاريخ اعتماد السياسة أو عند الضرورة			تاريخ المراجعة القادمة	
1SP0006			رقم المستند	
منصة شاهين الرقمية			مالك السياسة	
إدارة الجودة والتطوير			إعدت بواسطة	
مسؤولو القطاعات والإدارات الذين راجعوا السياسة ووافقوا عليها				
التوقيع	التاريخ	الأسم	الوظيفة	الإدارة
	2025-12-28	تركي عبدالله العبدلي	مدير إدارة الإلتزام والامتثال	الإدارة الرقابية
	2025-11-26	عنه: هاني هاشم	مدير إدارة الجودة والتطوير	رئيس مراجعة السياسات
اعتماد السياسة				
	2025-12-28	بدر سعد الشايع	العضو المنتدب	الإدارة العليا



1. المقدمة:

1.1 تُعد سياسة إدارة الوصول وحماية المستخدمين جزءًا أساسيًا لإطار الأمن المعلوماتي من خلال منع أي وصول غير مصرح به وضمان الفصل بين الصلاحيات والتحقق المستمر من هوية المستخدمين، بما يضمن حماية البيانات، واستمرارية الأعمال، والامتثال التنظيمي.

2. الهدف من السياسة:

2.1 تثق شركة الوثيقة الماسية لوساطة التأمين (ويشار إليها فيما يلي بـ "شاهين") في أن الهدف من هذه السياسة هو تنظيم إنشاء الحسابات، وتحديد الصلاحيات، وتطبيق ضوابط المصادقة والتحقق من الهوية، وضمان الاستخدام الآمن والمسؤول للأنظمة التقنية بما يحقق حماية أصول المعلومات، ويمنع الوصول غير المصرح به، ويضمن الامتثال الكامل للمتطلبات الصادرة عن الجهات الرقابية ذات العلاقة.

3. تعاريف:

- 3.1 منصة شاهين (Shahin Platform): المنصة الرقمية التابعة للشركة، والمتخصصة في ربط المنصة كوسيط تأميني بشركات التأمين لتسهيل عمليات الإصدار والتجديد وإدارة العملاء إلكترونياً.
- 3.2 الوصول (Access): عملية تمكين المستخدم من الاطلاع على نظام أو بيانات أو مورد تقني.
- 3.3 المستخدم (User): أي موظف أو متعاقد أو جهة خارجية تُمنح صلاحيات للوصول إلى أنظمة الشركة.
- 3.4 الحساب (Account): هوية إلكترونية مخصصة للمستخدم داخل النظام تشمل بيانات الدخول وكلمة المرور.
- 3.5 الصلاحية (Privilege): مستوى الوصول الممنوح للمستخدم وفقاً لوظيفته أو دوره.
- 3.6 المصادقة (Authentication): آلية التحقق من هوية المستخدم قبل السماح بالوصول.
- 3.7 المصادقة المتعددة (MFA): أسلوب أمني يتطلب استخدام أكثر من وسيلة للتحقق من هوية المستخدم.
- 3.8 الحد الأدنى من الامتيازات: مبدأ يمنح المستخدم أقل قدر من الصلاحيات اللازمة لأداء مهامه فقط.
- 3.9 الحساب الإداري (Privileged Account): حساب يمنح صلاحيات متقدمة للوصول إلى البنية التحتية أو إعدادات النظام.
- 3.10 الجهة الخارجية: أي طرف ثالث يحصل على وصول مؤقت أو دائم إلى أنظمة الشركة.

4. نطاق تطبيق السياسة :

- 4.1 تُطبق هذه السياسة على
 - 4.1.1 موظفي الشركة الدائمين والمؤقتين.
 - 4.1.2 المتعاقدين والمستشارين الخارجيين.
 - 4.1.3 مزودي الخدمات التقنية وشركات الدعم الخارجي التي يُمنح أفرادها وصولاً لأي نظام تابع للشركة.
 - 4.1.4 جميع الأنظمة، المنصات، الخوادم، الحسابات البريدية، والتطبيقات الداخلية والخارجية التي تُدار تحت إشراف إدارة تقنية المعلومات.

5. القطاعات والإدارات ذات العلاقة:

- 5.1 إدارة تقنية المعلومات .
- 5.2 قسم الأمن السيبراني.
- 5.3 إدارة الموارد البشرية.

6. الكيانات ذات العلاقة:

- 6.1 الهيئة الوطنية للأمن السيبراني (NCA).
- 6.2 الهيئة السعودية للبيانات والذكاء الاصطناعي (SDAIA).
- 6.3 هيئة التأمين.
- 6.4 مزودو الخدمات التقنية المعتمدون لدى الشركة.



7. قواعد عامة:

7.1 الالتزام العام:

- 7.1.1 يجب على جميع الموظفين والمتعاقدين والجهات الخارجية الالتزام بهذه السياسة عند الوصول إلى أي نظام أو بيانات تخص الشركة.
- 7.1.2 يُلزم جميع المستخدمين باستخدام حسابات شخصية مخصصة وعدم مشاركة بيانات الدخول أو كلمات المرور مع أي طرف آخر.
- 7.1.3 تُعتبر بيانات الدخول والمصادقة جزءاً من المعلومات الحساسة التي تخضع للحماية بموجب ضوابط الهيئة الوطنية للأمن السيبراني (NCA) ولائحة حماية البيانات الشخصية الصادرة عن الهيئة السعودية للبيانات والذكاء الاصطناعي (SDAIA).
- 7.1.4 يُحظر إنشاء أو تفعيل أي حساب مستخدم خارج نطاق إدارة تقنية المعلومات أو دون موافقة خطية من مدير التقنية.

7.2 إنشاء الحسابات وإدارتها:

- 7.2.1 يجب ألا يُنشأ أي حساب مستخدم إلا بناءً على طلب رسمي موثق يتضمن المبررات التشغيلية، ومصدق من المدير المباشر وإدارة تقنية المعلومات.
- 7.2.2 يجب أن يُمنح لكل مستخدم معرف فريد (Unique ID) يتيح تتبع جميع الأنشطة المنفذة باسمه.
- 7.2.3 يُلزم فريق تقنية المعلومات بحفظ سجل إلكتروني لجميع الحسابات يتضمن: اسم المستخدم، تاريخ الإنشاء، نوع الوصول، حالة الحساب، وتاريخ آخر مراجعة.
- 7.2.4 يجب أن تُوقف أو تُحذف الحسابات فور انتهاء علاقة العمل أو المشروع، ولا يجوز الاحتفاظ بها إلا لأغراض التدقيق وفق المدة النظامية المحددة.
- 7.2.5 يجب على إدارة تقنية المعلومات تنفيذ مراجعة شاملة لجميع الحسابات الفعالة كل (6) أشهر للتحقق من سلامة الصلاحيات واستمرار الحاجة التشغيلية لها.

7.3 إدارة الصلاحيات وفصل المهام

- 7.3.1 يجب أن تُمنح الصلاحيات للمستخدمين بناءً على مبدأ "الحد الأدنى من الامتيازات" (Least Privilege) وبما يتناسب مع مهامهم الوظيفية فقط.
- 7.3.2 يُحظر منح أي موظف أكثر من مستوى صلاحية قد يؤدي إلى تضارب في المهام (Conflict of Duties).
- 7.3.3 يجب على المدير المباشر مراجعة الصلاحيات الممنوحة للموظفين عند أي تغيير في مهامهم أو نقلهم بين الإدارات.
- 7.3.4 تُحدث صلاحيات المستخدمين فور أي تعديل وظيفي أو انتهاء المهام، ويُوثق ذلك في سجل إلكتروني رسمي.
- 7.3.5 يجب أن تُعتمد صلاحيات الوصول الحرجة من قبل مدير تقنية المعلومات ومسؤول الأمن السيبراني قبل التفعيل.

7.4 المصادقة والتحقق من الهوية:

- 7.4.1 يجب تطبيق المصادقة المتعددة العوامل (MFA) على جميع الأنظمة التي تتضمن بيانات مالية أو تأمينية أو شخصية.
- 7.4.2 يُلزم المستخدمون باستخدام كلمات مرور قوية لا تقل عن (12) رمزاً وتحتوي على أحرف كبيرة وصغيرة وأرقام ورموز.
- 7.4.3 يجب تغيير كلمات المرور كل (90) يوماً كحد أقصى، ويُحظر إعادة استخدام كلمات المرور السابقة.
- 7.4.4 يُمنع استخدام كلمات المرور الافتراضية أو المشتركة أو المرسلة عبر البريد الإلكتروني دون تشفير.
- 7.4.5 يجب إيقاف الحساب بعد (5) محاولات دخول فاشلة متتالية وإشعار مدير تقنية المعلومات تلقائياً.
- 7.4.6 تُخزن بيانات الدخول والمفاتيح الأمنية باستخدام خوارزميات تشفير قوية مثل (SHA-256 / AES-256).

7.5 الحسابات الإدارية والمميزة (Privileged Accounts)

- 7.5.1 يُلزم بإنشاء حسابات إدارية مستقلة ومحدودة الاستخدام للأعمال التقنية فقط.
- 7.5.2 يُحظر استخدام الحسابات الإدارية في الأنشطة اليومية أو البريد الإلكتروني أو الأنظمة التشغيلية غير التقنية.
- 7.5.3 يجب تسجيل جميع الأنشطة المنفذة من الحسابات الإدارية في نظام التتبع الآلي (Audit Trail).
- 7.5.4 يجب تغيير كلمات مرور الحسابات الإدارية عند أي تغيير في الفريق الفني أو مغادرة أي موظف مسؤول عنها.
- 7.5.5 تُحفظ كلمات المرور الإدارية الحساسة في نظام خزانة إلكترونية آمنة (Password Vault) بإشراف مزدوج (Dual Control).

7.6 إدارة الوصول الخارجي والجهات الثالثة

- 7.6.1 يجب عدم منح أي جهة خارجية وصولاً إلى الأنظمة الداخلية إلا بموجب اتفاقية رسمية تتضمن بنود السرية وحماية البيانات.

- 7.6.2 يُلزم كل طرف خارجي باستخدام مصادقة متعددة العوامل (MFA) وتشفير الاتصال باستخدام بروتوكول (TLS 1.2 أو أعلى).
- 7.6.3 تُخصص لكل جهة خارجية حسابات منفصلة محددة الصلاحيات ويُحظر استخدامها من قبل موظفي الشركة.
- 7.6.4 تُلغى صلاحيات الوصول فور انتهاء العقد أو المشروع بعد أقصى (24) ساعة من تاريخ الانتهاء.
- 7.6.5 يجب على إدارة تقنية المعلومات مراجعة الحسابات الخارجية شهريًا للتحقق من صلاحيتها وسلامة استخدام الوصول.
- 7.7 إدارة الجلسات والسلوك المستخدم
- 7.7.1 يجب أن تُقفل الجلسات تلقائيًا بعد (15) دقيقة من عدم النشاط.
- 7.7.2 يُلزم المستخدم بقفل جهازه فور مغادرة المكتب أو مكان العمل.
- 7.7.3 يُمنع استخدام الأجهزة الشخصية أو الشبكات العامة للوصول إلى أنظمة الشركة إلا بموافقة مسبقة ووفق ضوابط محددة.
- 7.7.4 يجب مراقبة جميع الجلسات النشطة ورصد محاولات الدخول غير الاعتيادية وتحليلها أمنيًا.
- 7.8 المراقبة والتدقيق
- 7.8.1 يجب تفعيل أنظمة المراقبة الآلية (Audit Trail / SIEM) لتسجيل كل عمليات الدخول والتعديل والحذف والهيئة داخل الأنظمة.
- 7.8.2 يُلزم الأمن السيبراني بمراجعة السجلات أسبوعيًا للتحقق من الأنشطة غير المصرح بها أو محاولات الاختراق.
- 7.8.3 يجب حفظ السجلات في نظام آمن لمدة لا تقل عن (12) شهرًا وفق المتطلبات النظامية.
- 7.8.4 يُحظر حذف أو تعديل أو تعطيل أي سجل تدقيق دون موافقة خطية من مدير تقنية المعلومات.
- 7.9 إدارة دورة الحياة للحسابات (Account Lifecycle)
- 7.9.1 يجب توثيق دورة حياة كل حساب من تاريخ إنشائه حتى تاريخ إغلاقه النهائي في سجل إلكتروني معتمد.
- 7.9.2 يُحتفظ بسجلات الحسابات المغلقة وبيانات الدخول لمدة لا تقل عن (6) أشهر لأغراض المراجعة الأمنية فقط.
- 7.9.3 يجب على إدارة تقنية المعلومات التأكد من إزالة جميع الصلاحيات المرتبطة بالحسابات المحذوفة فورًا.
- 7.10 إدارة المفاتيح وكلمات المرور
- 7.10.1 يجب إدارة المفاتيح الأمنية وكلمات المرور ضمن نظام مركزي آمن يخضع للمراقبة الدورية.
- 7.10.2 يُلزم بتجديد المفاتيح (API Keys / Tokens) كل (90) يومًا، ويُحظر استخدامها لأكثر من تطبيق واحد.
- 7.10.3 يجب إلغاء المفاتيح غير النشطة فورًا وتوثيق ذلك في سجل التغيير.
- 7.10.4 عند الاشتباه بتسريب مفتاح أو كلمة مرور، يجب تعطيلها فورًا وتفعيل خطة الاستجابة للحوادث.
- 7.11 المراجعة بعد الحوادث الأمنية
- 7.11.1 يجب على الأمن السيبراني مراجعة جميع الصلاحيات والحسابات المرتبطة بأي حادث أمني خلال (24) ساعة من اكتشافه.
- 7.11.2 تُلغى مؤقتًا صلاحيات الوصول لأي حساب يشتبه في ارتباطه بالحادثة إلى حين انتهاء التحقيق.
- 7.12 التدريب والوعي الأمني
- 7.12.1 يجب تدريب جميع المستخدمين سنويًا على مفاهيم أمن المعلومات وإدارة كلمات المرور والممارسات الآمنة.
- 7.12.2 يُلزم كل مستخدم جديد بإتمام برنامج التهيئة الأمنية قبل منحه صلاحيات الدخول إلى الأنظمة.
- 7.12.3 تُوثق جميع الدورات التدريبية ويُحتفظ بسجلات إثبات المشاركة ضمن ملف الموظف.

8. مسؤولية السياسة.

8.1 إدارة تقنية المعلومات:

- 8.1.1 مسؤولون عن إنشاء الحسابات وتحديد الصلاحيات وفق الضوابط المعتمدة.
- 8.1.2 مسؤولون عن مراقبة الأنشطة اليومية وضبط محاولات الدخول غير المصرح بها.
- 8.1.3 مسؤولون عن تنفيذ آليات النسخ الاحتياطي والتدقيق الأمني على بيانات الدخول.

8.2 قسم الأمن السيبراني:

- 8.2.1 مسؤولون عن التحقق من امتثال ضوابط الوصول والمعايير الأمنية.
- 8.2.2 مسؤولون عن مراجعة سجلات الدخول الدورية وتحليل الثغرات المكتشفة.
- 8.2.3 مسؤولون عن رفع تقارير دورية للإدارة العليا تتضمن مستوى الامتثال والمخاطر المحتملة.

8.3 إدارة الموارد البشرية:

- 8.3.1 مسؤولون عن إخطار إدارة تقنية المعلومات فوراً عند تعيين أو إنهاء خدمة أي موظف لضمان تعديل أو إلغاء الحسابات ذات الصلة.

8.4 إدارة الجودة والتطوير:

- 8.4.1 مسؤولون عن التأكد من تطبيق هذه السياسات من خلال التدقيق والمراجعة الدورية.

9. التعميمات والتعليمات ذات العلاقة:

- 9.1 الهيئة السعودية للبيانات والذكاء الاصطناعي (SDAIA) — نظام حماية البيانات الشخصية".
- 9.2 الهيئة الوطنية للأمن السيبراني "الضوابط الأساسية للأمن السيبراني (ECC-1:2018)".
- 9.3 هيئة الحكومة الرقمية (DGA) — "ضوابط حوكمة تقنية المعلومات في الحكومة الرقمية"

10. حفظ السياسة:

- 10.1 تحفظ النسخة الإلكترونية الغير قابلة للنسخ من السياسة المعتمدة على نظام الموارد البشرية ويطلع عليها الإدارات ذات العلاقة.
- 10.2 تحفظ النسخة الورقية من السياسة المعتمدة في إدارة الجودة والتطوير حسب المدة النظامية المحددة في كتيب تقاؤم المستندات ترحل نظامياً إلى حفظ المستندات.

11. مخالفة السياسة:

- 11.1 يُطبق في حق المخالف لهذه السياسة ماورد في لائحة جزاءات شركة دايمنود المعتمدة.



Diamond Insurance Broker

**Access Management
and User Protection Policy**

Nov 2025

Registered Name: Diamond Insurance Broker Company

Head Office: Al Thumama Road, Al Rabie District, Riyadh

Document Owner: Quality & Development Manager

Internal

DO NOT COPY

Contents	
1	Introduction.....
2	Policy Objective.....
3	Definitions.....
4	Scope of Application.....
5	Related Management and Sectors.....
6	Related Entity.....
7	General Rules.....
8	Policy Responsibility.....
9	Related Circulars and Instructions.....
10	Policy Retention.....
11	Policy Violation.....



Article (1): This document and the information it contains are related to the Shahin digital platform. They may not be used, copied, or disclosed, in whole or in part, to any third party without the prior written consent of Diamond. This restricted notice may not be altered or removed from this document under any circumstances.

Article (2): In the event of any discrepancy between the Arabic and English texts, the Arabic text shall prevail.

1. Introduction

1.1 The Access Management and User Protection Policy is a fundamental part of the information security framework, as it prevents unauthorized access, ensures segregation of privileges, and enables continuous verification of user identity—thereby safeguarding data, ensuring business continuity, and supporting regulatory compliance.

2. Policy Objective

2.1 Diamond Insurance Brokers Company (hereinafter referred to as “Shahin”) believes that the objective of this policy is to regulate account creation, privilege assignment, and the implementation of authentication and identity verification controls, and to ensure the secure and responsible use of IT systems in a manner that protects information assets, prevents unauthorized access, and ensures full compliance with requirements issued by relevant regulatory authorities.

3. Definitions

3.1 **Shahin Platform:** The Company’s digital platform, specialized in connecting—acting as an insurance broker—with insurance companies to facilitate electronic issuance, renewal, and customer management.

3.2 **Access:** The process of enabling a user to view or use a system, data, or a technical resource.

3.3 **User:** Any employee, contractor, or external party granted access privileges to the Company’s systems.

3.4 **Account:** An electronic identity assigned to a user within a system, including login credentials and a password.

3.5 **Privilege:** The level of access granted to a user based on their job function or role.

3.6 **Authentication:** A mechanism used to verify a user’s identity before granting access.

3.7 **Multi-Factor Authentication (MFA):** A security method requiring more than one verification factor to confirm a user’s identity.

3.8 **Least Privilege:** A principle that grants a user the minimum level of access required to perform their duties only.

3.9 **Privileged Account:** An account that provides elevated access to infrastructure or system configuration settings.

3.10 **External Party:** Any third party granted temporary or permanent access to the Company’s systems.

4. Scope of Application

4.1 This policy applies to:

4.1.1 Permanent and temporary employees of the Company.

4.1.2 External contractors and consultants.

4.1.3 Technology service providers and external support companies whose personnel are granted access to any Company system.

4.1.4 All systems, platforms, servers, email accounts, and internal/external applications managed under the supervision of the IT Department.

5. Related Management and Sectors

5.1 Information Technology Department.

5.2 Cybersecurity Department/Function.

5.3 Human Resources Department.

6. Related Entities

6.1 National Cybersecurity Authority (NCA).

6.2 Saudi Data & AI Authority (SDAIA).

6.3 Insurance Authority.

6.4 Technology service providers approved by the Company.

7. General Rules

7.1 General Compliance

7.1.1 All employees, contractors, and external parties shall comply with this policy when accessing any system or data owned by the Company.

7.1.2 All users shall use assigned personal accounts and shall not share login credentials or passwords with any other party.

7.1.3 Login and authentication data shall be treated as sensitive information protected under the National Cybersecurity Authority (NCA) controls and the Personal Data Protection Law issued by the Saudi Data & AI Authority (SDAIA).

7.1.4 Creating or activating any user account outside the scope of the IT Department, or without written approval from the IT Director, is prohibited.

7.2 Account Creation and Management

7.2.1 No user account shall be created except based on a documented official request that includes operational justification and is approved by the direct manager and the IT Department.

7.2.2 Each user shall be assigned a unique identifier (Unique ID) enabling traceability of all actions performed under their identity.

7.2.3 The IT team shall maintain an electronic register for all accounts, including: username, creation date, access type, account status, and last review date.

7.2.4 Accounts shall be suspended or deleted immediately upon termination of employment or completion of the relevant project, and may only be retained for audit purposes in accordance with applicable regulatory retention periods.

7.2.5 The IT Department shall conduct a comprehensive review of all active accounts every **six (6) months** to validate privilege accuracy and ongoing operational need.

7.3 Privilege Management and Segregation of Duties

7.3.1 User privileges shall be granted based on the principle of **Least Privilege** and strictly in line with job duties.

7.3.2 Granting any employee privileges that may result in a **Conflict of Duties** is prohibited.

7.3.3 The direct manager shall review granted privileges whenever an employee's duties change or they transfer between departments.

7.3.4 User privileges shall be updated immediately following any job change or task completion, and the update shall be documented in an official electronic register.

7.3.5 Critical access privileges shall be approved by the IT Director and the CISO prior to activation.

7.4 Authentication and Identity Verification

7.4.1 Multi-Factor Authentication (MFA) shall be implemented for all systems containing financial, insurance, or personal data.

7.4.2 Users shall use strong passwords of at least **twelve (12)** characters, including uppercase and lowercase letters, numbers, and symbols.

7.4.3 Passwords shall be changed at least every **ninety (90) days**, and reuse of previous passwords is prohibited.

7.4.4 The use of default, shared, or unencrypted emailed passwords is prohibited.

7.4.5 Accounts shall be locked after **five (5)** consecutive failed login attempts, with an automatic notification sent to the IT Director.

7.4.6 Credentials and security keys shall be stored using strong encryption algorithms such as **SHA-256 / AES-256**.

7.5 Privileged Accounts

7.5.1 Separate, restricted privileged accounts shall be created for technical administration only.

7.5.2 Privileged accounts shall not be used for daily activities, email, or non-technical operational systems.

7.5.3 All activities performed using privileged accounts shall be logged within the automated audit trail system.

7.5.4 Privileged account passwords shall be changed whenever the technical team changes or any responsible employee leaves.

7.5.5 Sensitive privileged passwords shall be stored in a secure **Password Vault** under **Dual Control**.

7.6 External Access and Third Parties

7.6.1 No external party shall be granted access to internal systems except under a formal agreement that includes confidentiality and data protection clauses.

7.6.2 External parties shall be required to use MFA and encrypt connections using **TLS 1.2 or higher**.

7.6.3 Separate accounts with strictly defined privileges shall be assigned to each external party, and their use by Company employees is prohibited.

7.6.4 Access privileges shall be revoked immediately upon contract or project end, within a maximum of **twenty-four (24) hours** from the end date.

7.6.5 The IT Department shall review external accounts monthly to confirm validity and appropriate use.

7.7 Session Management and User Behavior

7.7.1 Sessions shall automatically lock after **fifteen (15) minutes** of inactivity.

7.7.2 Users shall lock their devices immediately when leaving their desk or workplace.

7.7.3 Accessing Company systems through personal devices or public networks is prohibited unless prior approval is obtained and specific controls are applied.

7.7.4 All active sessions shall be monitored, and unusual login attempts shall be detected and analyzed from a security perspective.

7.8 Monitoring and Audit

7.8.1 Automated monitoring systems (Audit Trail / SIEM) shall be enabled to log all login, modification, deletion, and configuration activities within systems.

7.8.2 The cybersecurity function shall review logs weekly to identify unauthorized activity or attempted breaches.

7.8.3 Logs shall be securely retained for no less than **twelve (12) months** in accordance with regulatory requirements.

7.8.4 Deleting, modifying, or disabling any audit log without written approval from the IT Director is prohibited.

7.9 Account Lifecycle Management

7.9.1 The lifecycle of each account—from creation through final closure—shall be documented in an approved electronic register.

7.9.2 Records of closed accounts and credentials shall be retained for no less than **six (6) months** for security review purposes only.

7.9.3 The IT Department shall ensure removal of all privileges associated with deleted accounts immediately.

7.10 Key and Password Management

7.10.1 Security keys and passwords shall be managed through a secure centralized system subject to periodic monitoring.

7.10.2 API keys/tokens shall be rotated every **ninety (90) days**, and shall not be used for more than one application.

7.10.3 Inactive keys shall be revoked immediately and documented in the change log.

7.10.4 If a key or password is suspected to be compromised, it shall be disabled immediately and the incident response plan shall be activated.

7.11 Post-Incident Review

7.11.1 The cybersecurity function shall review all privileges and accounts associated with any security incident within **twenty-four (24) hours** of detection.

7.11.2 Access privileges for any account suspected to be linked to the incident shall be temporarily revoked until the investigation is concluded.

7.12 Training and Security Awareness

7.12.1 All users shall receive annual training on information security, password management, and secure practices.

7.12.2 Every new user shall complete a security induction program before being granted system access privileges.

7.12.3 All training courses shall be documented, and participation evidence shall be retained in the employee file.

8. Policy Responsibility

8.1 Information Technology Department

8.1.1 Responsible for creating accounts and assigning privileges in accordance with approved controls.

8.1.2 Responsible for monitoring daily activities and controlling unauthorized access attempts.

8.1.3 Responsible for implementing backup mechanisms and security auditing for access credentials.

8.2 Cybersecurity Function

8.2.1 Responsible for verifying compliance with access controls and security standards.

8.2.2 Responsible for reviewing access logs periodically and analyzing identified vulnerabilities.

8.2.3 Responsible for submitting periodic reports to senior management on compliance level and potential risks.

8.3 Human Resources Department

8.3.1 Responsible for notifying the IT Department immediately upon hiring or termination of any employee to ensure modification or deactivation of related accounts.

8.4 Quality and Development Department

8.4.1 Responsible for ensuring the implementation of this policy through periodic audit and review.

9. Related Circulars and Instructions

9.1 Saudi Data & AI Authority (SDAIA) — Personal Data Protection Law (PDPL).

9.2 National Cybersecurity Authority — Essential Cybersecurity Controls (ECC-1:2018).

9.3 Digital Government Authority (DGA) — "IT Governance Controls in Digital Government".

10. Policy Retention

10.1 The approved non-editable electronic version of the policy shall be retained in the HR system and made accessible to the relevant departments.

10.2 The approved hard copy shall be retained by the Quality & Development Department in accordance with the retention period specified in the Document Retention Schedule, and then archived in accordance with the approved records retention process.

11. Policy Violation

11.1 Any violation of this policy shall be subject to the penalties stipulated in Diamond's approved Disciplinary and Sanctions Policy.